

Анкета для оценки состояния информационной безопасности (киберустойчивости)

Наименование организации Общество с ограниченной ответственностью «ГС Ритейл»
 Вид экономической деятельности Разработка, публикация ПО, продажа лицензий
 Юридический адрес 223060, Республика Беларусь, Минская область, Минский район, Новодворский сельсовет, д. Большое Стиклево, д. 40, корп. 2, пом. 41
 Форма собственности Общество с ограниченной ответственностью (частная форма собственности)
 Контактное лицо Пономарев А.В., +375 29 6678873

№ п/п	Вопрос	Ответ
1	2	3
1.	Существует в Вашей организации специализированное подразделение (должностное лицо), выполняющее работы по технической защите информации?	☐ Да. ☐ Нет. Должностное лицо
2.	Сколько специалистов в данном подразделении?	☒ Один. ☐ Два и более.
3.	Существует в Вашей организации лицо, ответственное за техническую защиту информации?	☒ Да. ☐ Нет.
4.	Какие компетенции у специалистов (должностного лица), выполняющих работы по технической защите информации?	☐ Специалисты имеют высшее образование в области защиты информации. ☐ Специалисты прошли переподготовку или повышение квалификации по вопросам информационной безопасности. ☐ Специалисты имеют действующие международные сертификаты.
5.	Кто в Вашей организации ответственный за работы по технической защите информации? (Выберите один вариант ответа)	☐ Руководитель организации. ☒ Директор по информационным технологиям (ИТ). ☐ Выделенный директор по информационной/кибербезопасности. ☐ Руководитель иной службы. ☐ Специалисты по ИТ/ИБ.
6.	Какие перечисленные направления включены в зону ответственности подразделения информационной безопасности в Вашей организации?	☐ Обучение сотрудников. ☐ Обеспечение непрерывности бизнеса/восстановления деятельности после сбоев. ☐ Обеспечение сетевой безопасности. ☐ Контроль прав доступа. ☐ Аудит информационной безопасности. ☐ Управление рисками информационной безопасности/киберрисками. ☐ Обеспечение антивирусной защиты информации. ☐ Управление уязвимостями.
7.	Внедрена ли система защиты информации в Вашей организации в соответствии с Приказом Оперативно-аналитического центра при Президенте Республики Беларусь от 20.02.2020 № 66, иными требованиями национального законодательства (при положительном ответе необходимо предоставить подтверждение)?	☐ Да, внедрена и официально аттестована. ☐ Система защиты информации внедрена, но не аттестована. ☒ Нет.

1	2	3
8.	Выберите пункты, применимые к политике информационной безопасности (ИБ) Вашей организации?	☐ За последние 12 месяцев проводились пересмотр Политики и ее обновление. ☐ Политика была официально утверждена высшим руководством организации. ☐ В политике регламентированы принципы организации и функционирования системы ИБ организации. ☐ В политике рассматриваются правовые аспекты обеспечения безопасности. ☐ Политика доведена до сведения всех работников Вашей организации (включая штатных сотрудников, подрядчиков, временных сотрудников и третьих лиц). ☐ В политике определены требования к перечню частных политик, развивающих и детализирующих политику ИБ. ☒ Необходимость создания единой политики ИБ отсутствует – перейти к вопросу 9.
9.	Какие из перечисленных разделов определены политикой информационной безопасности или другими нормативными документами в области информационной безопасности?	☐ Классификация данных/информации. ☒ Использование электронной почты и Интернета. ☐ Использование мобильных или портативных устройств/носителей (планшеты, смартфоны, USB-носители и т. п.). ☐ Обеспечение конфиденциальности данных/защиты персональных данных. ☒ Требования к используемым паролям. ☐ Хранение/уничтожение данных/информации. ☒ Меры по защите информации контрагентов при оказании услуг Вашей организацией на основании заключенных договоров. ☒ Порядок предоставления доступов. ☐ Порядок обеспечения антивирусной защиты.
10.	Каким образом в Вашей организации производится оценка эффективности работы процесса обеспечения информационной безопасности?	☒ Самостоятельная внутренняя оценка силами службы ИТ. ☐ Самостоятельная внутренняя оценка силами службы информационной безопасности. ☐ Проведение оценки службой внутреннего аудита. ☐ Регулярная оценка внешними аудиторами. ☐ Официальная сертификация в соответствии с международными стандартами безопасности. Перечислите и предоставьте копии полученных сертификатов (PCI DSS, ISO и т. д.): ☐ Необходимость проведения оценки отсутствует.
11.	Какие механизмы используются в Вашей организации для повышения эффективности управления процессом информационной безопасности?	☐ Внедрение средств непрерывного мониторинга событий ИБ. ☒ Аутсорсинг отдельных мероприятий в области безопасности. ☐ Внедрение средств управления учетными записями. ☐ Внедрение дополнительных средств обеспечения безопасности. ☐ Необходимость применения механизмов отсутствуют.
12.	Какие из перечисленных средств в Вашей организации используются для контроля за утечкой конфиденциальной информации? (Выберите все подходящие варианты)	☐ Внедрены средства мониторинга/фильтрации контента (DLP). ☐ Внедрены средства анализа журнала событий. ☐ Применяется блокировка/ограничение использования отдельных компонентов аппаратного обеспечения. ☐ Разработана специальная политика в отношении классификации конфиденциальной информации и порядка работы с ней. ☐ Внедрены дополнительные механизмы безопасности в целях защиты информации (например, шифрование). ☒ Ограничено/запрещено использование систем мгновенного обмена сообщениями или электронной почты для передачи конфиденциальной информации. ☐ Необходимость контроля отсутствует.
13.	Как осуществляется управление корпоративными активами (устройствами конечных пользователей) и программным обеспечением (операционными системами и приложениями) в сети?	☐ Проводится инвентаризация всех активов предприятия, которые способны хранить или обрабатывать данные (ежегодно или чаще). ☐ Проводится еженедельная проверка неавторизованных активов. ☐ Используется активный инструмент обнаружения для идентификации активов, подключенных к корпоративной сети: ☐ Ведется инвентаризация всего лицензионного программного обеспечения. ☒ Используются технические средства контроля, такие как списки разрешенных приложений.

1	2	3
14.	Какие из перечисленных технологий Ваша организация использует?	☒ Системы управления доступом и учетными записями (перечислите): Microsoft Active Directory (AD) ☒ Многофакторная аутентификация. ☐ Программные средства корпоративного управления, управления рисками и соблюдения нормативных требований. ☐ Средства мониторинга/фильтрации контента. ☐ Шифрование съемных носителей. ☐ Шифрование электронной почты. ☐ Использование биометрических средств. ☒ Сегментирование сети, межсетевые экраны. ☒ Антивирусные средства защиты информации. ☒ Использование VPN. ☒ Ограниченное использование учетных записей, имеющих административные привилегии. ☐ Наличие перечня разрешенного программного обеспечения.
15.	Существует ли в Вашей организации резервная инфраструктура, включая центр обработки данных?	☐ Да. ☒ Частично в отношении критичной информации. ☐ Необходимость отсутствует.
16.	Как в инфраструктуре организовано управление уязвимостями в корпоративных активах?	☐ Выявление уязвимостей происходит в соответствии с планом-графиком сканирования. ☒ Выявление вручную, по результатам анализа версий используемого ПО, устранение в рабочем порядке. ☐ Выполняется автоматическое сканирование внутренних активов организации на наличие уязвимостей раз в квартал или чаще. ☐ Обнаруженные уязвимости в программном обеспечении устраняются в течении месяца. ☐ Нет необходимости.
17.	Как часто в Вашей организации проводится анализ защищенности сети и приложений?	☐ Ежеквартально или чаще. ☒ Раз в год. ☐ Нет необходимости.
18.	Переданы ли в Вашей организации какие-либо функции по обеспечению информационной безопасности на аутсорсинг?	☐ Услуги оказываются аттестованным центром кибербезопасности (укажите наименование, подтверждающие документы): ☐ Да (перечислите функции): ☐ Нет.
19.	Были ли за последний год реализованы угрозы информационной безопасности?	☐ Да, одна. ☐ Более одной. ☒ Нет.
20.	Как в Вашей организации обеспечиваются регистрация событий безопасности и сбор доказательств по инцидентам информационной безопасности?	☐ Не производится. ☒ Организован сбор, просмотр и хранение журналов регистрации событий стандартными средствами ОС и ПК. ☐ Обеспечивается иными средствами (например, SIEM-системы): _____ _____
21.	Как в Вашей организации осуществляется внутренний контроль за обработкой персональных данных?	☒ Сотрудники, непосредственно осуществляющие обработку персональных данных, ознакомлены с положениями законодательства о защите персональных данных. ☒ Утверждены документы, определяющие политику в отношении обработки персональных данных. ☐ Установлен порядок доступа к персональным данным. ☐ Осуществлена техническая и криптографическая защита персональных данных в порядке, установленном Оперативно-аналитическим центром при Президенте Республики Беларусь, в соответствии с классификацией информационных ресурсов (систем), содержащих персональные данные.

1	2	3
22.	Какие меры реализованы в части управления учетными записями пользователей?	☒ Доступ предоставляется на основании оформленных заявок. ☐ Проводится ежеквартальная инвентаризация всех учетных записей пользователей и администраторов. ☐ Отключены все бездействующие учетные записи после периода бездействия в течение более 45 дней. ☐ Управление учетными записями централизовано через сервис каталога Active Directory. ☒ Доступ отзывается по кадровым событиям. ☐ Осуществляется автоматизированный процесс для предоставления доступа к активам организации. ☐ Осуществляется автоматизированный процесс для отзыва доступа к активам организации путем отключения учетных записей сразу после прекращения действия прав. ☒ Все открытые извне корпоративные или сторонние приложения применяют 2FA (где это поддерживается). ☒ Применяется 2FA для удаленного доступа к сети.
23.	Как организована защита и обнаружение угроз из электронной почты?	☒ Используются только последние версии браузеров и почтовых клиентов. ☐ Используются службы DNS-фильтрации на всех корпоративных ресурсах (чтобы заблокировать доступ к известным вредоносным доменам). ☐ Регулярно обновляются сетевые фильтры URL-адресов. ☐ Отключены ненужные плагины и дополнительные приложения для браузера/почтового клиента. ☒ Потенциально опасные расширения файлов, блокируются на почтовом шлюзе предприятия. ☒ Внедрены средства защиты почтового трафика от вредоносных программ, такие как сканирование вложений. ☐ Используется технология песочницы.
24.	Как предотвращаются установка, распространение и выполнение вредоносных приложений/кода/скриптов на корпоративных ресурсах?	☐ Используется программное обеспечение для защиты от вредоносных программ на всех корпоративных ресурсах. ☐ Настроено автоматическое обновление сигнатур защиты от вредоносных программ на всех корпоративных ресурсах. ☐ Отключены функции автозапуска и автовоспроизведения для съемных носителей. ☒ Антивирусное программное обеспечение настроено на периодическое автоматическое сканирование. ☐ Используется программное обеспечение для защиты от вредоносных программ, основанное на поведении (EDR-решения).
25.	Разработаны ли методы восстановления данных (достаточные для восстановления корпоративных активов в состоянии до инцидента и в доверенном состоянии)?	☐ Выполняется автоматизированное резервное копирование всех корпоративных активов. ☒ Выполняется автоматизированное резервное копирование критически важных активов. ☐ Не выполняется.
26.	Как осуществляется мониторинг сети?	☐ Организовано централизованное оповещение о событиях безопасности на корпоративных ресурсах для корреляции и анализа журналов (SIEM-система). ☐ Развернуто хост-решение для обнаружения вторжений на корпоративных активах. ☒ Организовано управление контролем доступа активов, удаленно подключающимся к корпоративным ресурсам. ☐ Анализируются журналы потоков сетевого трафика для просмотра и анализа событий с сетевых устройств.
27.	Проводится ли обучение (не реже раза в год) сотрудников основам информационной безопасности?	☐ Проводится (необходимо предоставить подтверждающие документы (сертификаты, дипломы, планы обучения и т. д.)). ☒ Не проводится.
28.	Как организован механизм реагирования на инциденты?	☐ Назначен работник, отвечающий за координацию и документирование действий по реагированию на инциденты и восстановлению. ☐ Разработан регламент реагирования на инциденты. ☐ Проводятся учения по сценариям реагирования на инциденты для персонала, участвующего в процессе реагирования на инциденты. ☒ Проводятся разборы инцидентов после их устранения.

1	2	3
29.	Как проверяется эффективность и отказоустойчивость активов предприятия?	☐ Разработаны и поддерживаются программы тестирования на проникновение. ☐ Периодически выполняются внешние тесты на проникновение в соответствии с требованиями программы (не реже одного раза в год). ☐ Периодически выполняются внутренние тесты на проникновение в соответствии с требованиями программы (не реже одного раза в год).
30.	Компания, офисы, дочерние или материнские организации располагаются за пределами Республики Беларусь?	☐ Да, в странах СНГ. ☐ Да, в остальных странах. ☒ Нет.
31.	Посредством каких технологий происходит обмен информацией ограниченного распространения между работниками компании?	☒ Корпоративная почта. ☐ Мессенджеры/социальные сети (укажите): ☐ Посредством сертифицированных средств криптографической защиты информации (укажите): ☐ Не производится.

&&&

Настоящим подтверждаем, что:

1. Представленная информация является полной и достоверной на момент подписания настоящей Анкеты. Не возражаем против проверки ОАО «АСБ Беларусбанк» в любое время всех сведений, содержащихся в настоящей Анкете и иных представленных документах, в том числе обязуемся предоставить дополнительную информацию по запросу Банка.

2. Согласны, что в случае неточностей и несоответствия информация трактуется на усмотрение Банка.

3. Согласны на хранение копий представленных документов и оригинала настоящей Анкеты в ОАО «АСБ Беларусбанк» даже в случае, если договор не будет заключен.

Руководитель _____

/ Есис Г.В. _____

